



An Overview of the General Data Protection Regulation (GDPR)

GROUP-3

BOYA LOKESH - MS21A010
SAYAN BHOWMICK- MS21A060
VIJAY KUMAR - MS21A073

OVERVIEW OF SOCIAL MEDIA USE

HEADLINES FOR SOCIAL MEDIA ADOPTION AND USE (NOTE: USERS MAY NOT REPRESENT UNIQUE INDIVIDUALS)



NUMBER OF SOCIAL MEDIA USERS



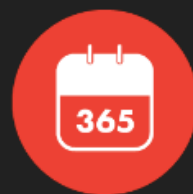
4.76
BILLION

QUARTER-ON-QUARTER CHANGE IN SOCIAL MEDIA USERS



+0.5%
+23 MILLION

YEAR-ON-YEAR CHANGE IN SOCIAL MEDIA USERS



+3.0%
+137 MILLION

AVERAGE DAILY TIME SPENT USING SOCIAL MEDIA



2H 31M
YOY: +2.0% (+3M)

AVERAGE NUMBER OF SOCIAL PLATFORMS USED EACH MONTH



7.2
YOY: -4.6%

SOCIAL MEDIA USERS vs. TOTAL POPULATION



59.4%

SOCIAL MEDIA USERS AGE 18+ vs. POPULATION AGE 18+



77.8%

SOCIAL MEDIA USERS vs. TOTAL INTERNET USERS



92.3%

FEMALE SOCIAL MEDIA USERS: SHARE OF TOTAL USERS

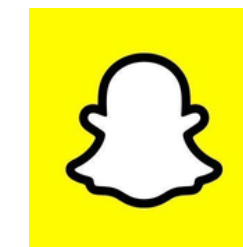
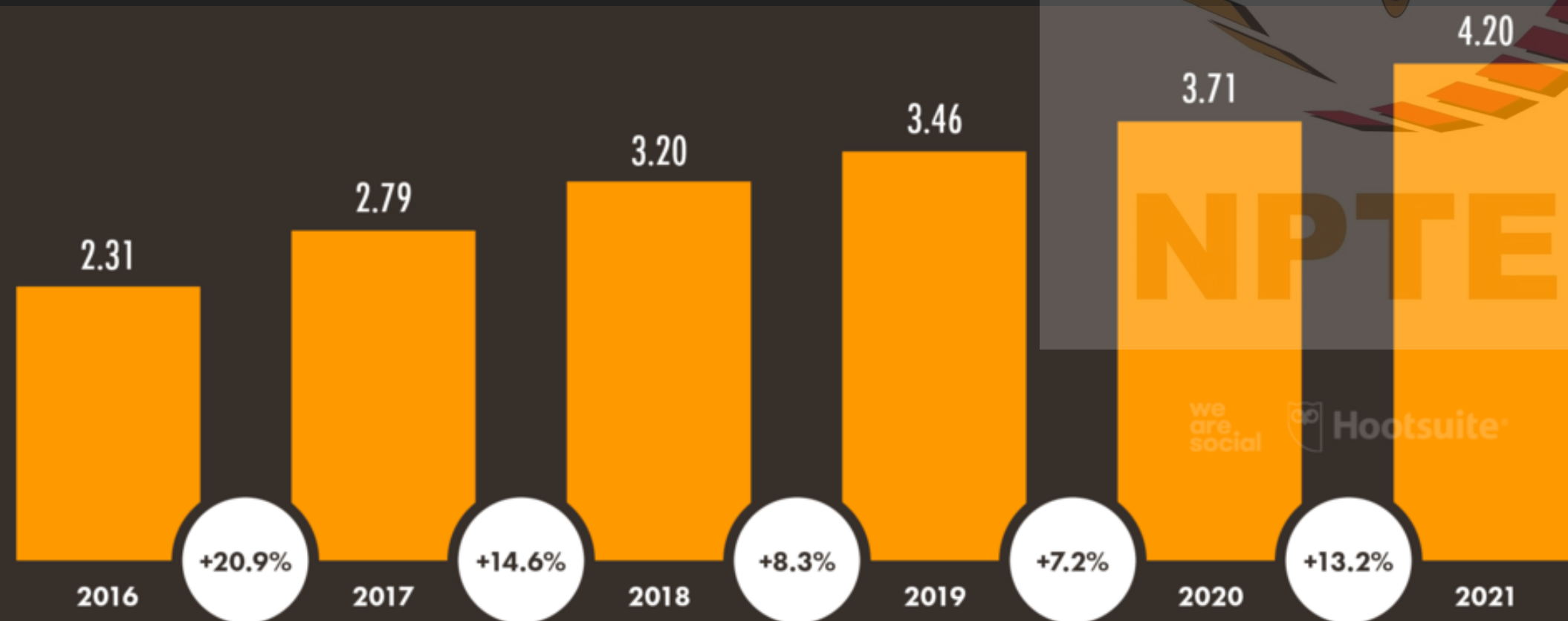


46.3%

MALE SOCIAL MEDIA USERS: SHARE OF TOTAL USERS



53.7%



Quora



shaadi.com



Why Data privacy law like GDPR is essential ?

- Rapid growth of internet users across the world.
- Large scale processing of sensitive personal data by digital media.
- Globalization enabling constant collection, processing and sharing of personal data across nation state.
- Social media data analytics has found increased usage in laying foundation of digital marketing campaigns.
- Digital marketers are eager on spending bucks for getting personal data.



What is GDPR?

- **GDPR stands for General Data Protection Regulation.**
- **It is a comprehensive data privacy law which was adopted on 27th April, 2016 and became enforceable on 25th May, 2018 replacing earlier 1995 EU data protection directive.**
- **More stringent rules , more empowerment of individuals using digital media.**

Where does GDPR apply?

- **GDPR applies to the all the establishments in EU whether it is a data controller or processor in the context of personal data processing, regardless of whether it takes place in the Union or not.**
- **It applies to all organization outside EU when they are dealing with personal data of individuals residing in EU.**

Which data is GDPR concerned with?

Does GDPR apply to organizations indirectly processing data?

- The GDPR regulates the collection, storage, use, and sharing of “personal data.”
- “Personal data” includes any data that relates to an identified or identifiable individual like online identifiers (e.g., IP addresses , geo location data), employee information, sales databases, biometric data, CCTV footage, health and financial information and much more.

GDPR not only applies to "controllers" i.e. organizations that collect and process data for their own purposes but as well as to "processors", the organizations that process data on behalf of the controllers.



Key principles of GDPR



Lawfulness, fairness
and transparency

Individuals must be
clear on how their data
is being used.



Purpose limitation

Process personal data
only for specified,
explicit and legitimate
purposes.



Minimize collection
of personal data

Store only data
adequate and relevant
for the process

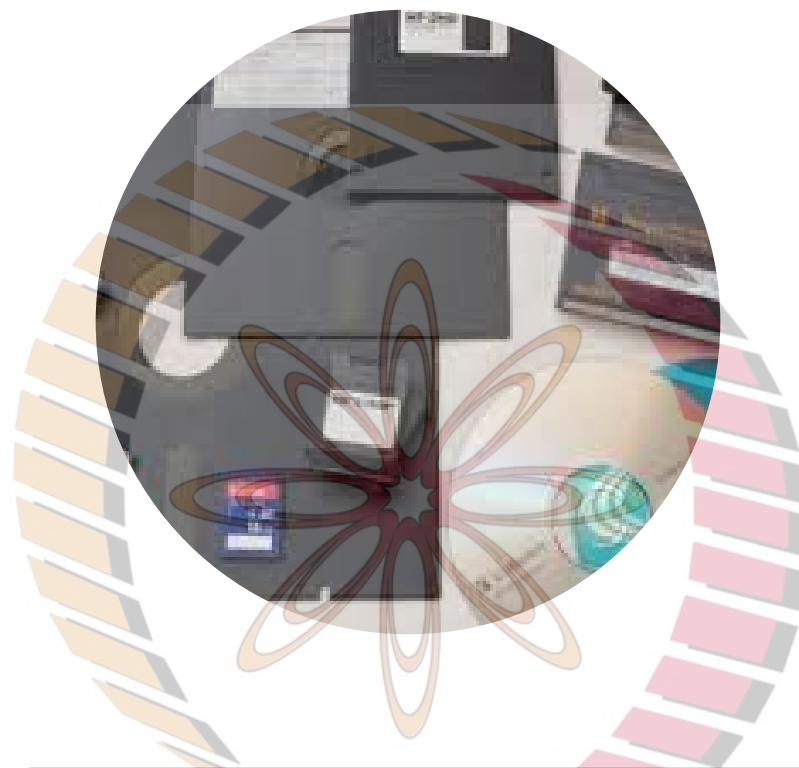


Key principles of GDPR



Ensure Data accuracy

Individual data stored by the organization has to be accurate. Data subjects have right to get their data corrected or erased.



Limit data storage

If purpose is served and personal data is no more required then do not retain them anymore.



Ensure confidentiality, security and integrity

Data storage and processing should comply with CIA triad.



RISK : NON COMPLIANCE OF GDPR

Civil litigation against organizations that breach the GDPR

4% of an organization's annual global revenue.

The maximum fine for serious infringements will be the greater of €20 million

AMAZON

Amazon was fined \$780.9 mn for tracking user data without acquiring appropriate consent from users or providing the means to opt out from this tracking

WHATSAPP

WhatsApp was fined \$247 mn for unclear privacy policies and a lack of transparency in how it was using user data..

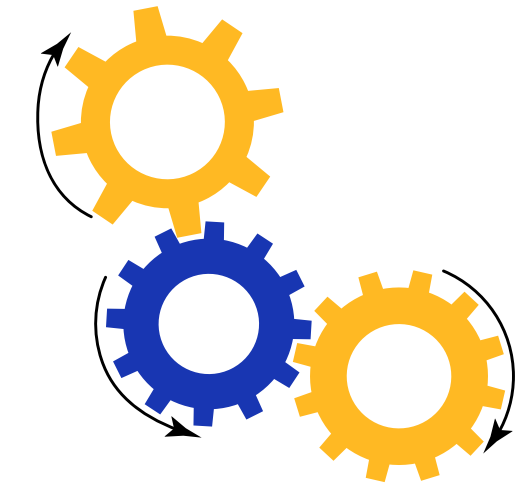
GOOGLE

Google was fined \$66 mn for failing to give users an easy way to refuse cookies under both the GDPR and the ePrivacy Directive.

BRITISH AIRWAYS

The airline was fined \$26 mn for failing to prevent a massive data breach that exposed the personal data of 400,000 customers and failing to spot and respond to the breach in a timely fashion.





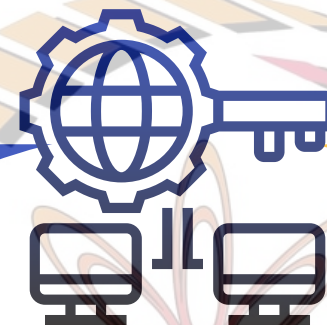
TRANSPARENCY: GDPR



RULE

Organizations must tell individuals about processing of personal data.

Why the personal data is being processed?



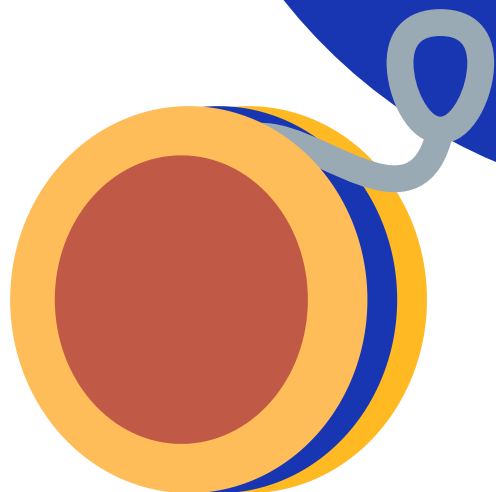
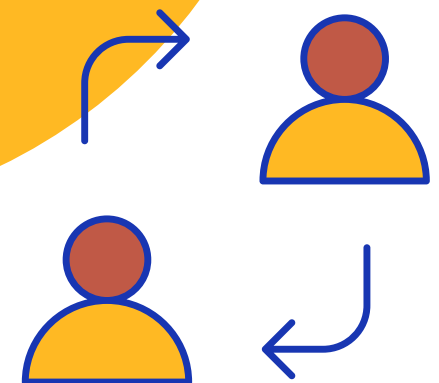
This information must be presented in a way that is clear and easily accessible.

NPTTEL



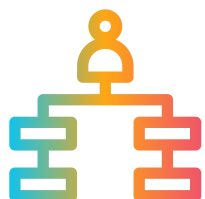
RULE

- How long the data will be stored?
- with whom the personal data will be shared?





LEGAL BASIS : GDPR



Organization can't process personal data simply because they want it.



Organizations must point to a "legal basis" for processing



Six legal bases for processing personal data



Consent

If the person to whom the personal data belongs to has agreed to the processing for one or more clearly defined purposes, the data processing is lawful



Vital interests

This applies when someone's life is in danger, and the processing is necessary in order to save it.



Contract

When an organization enters into a contract with the data subject and needs to process their personal data in order to fulfil that contract, the data processing is lawful.

Public interest

If the data processing is necessary for carrying out a task in the public interest or in the exercise of official authority, the data processing is legal.



Legal obligations

If a company has to process personal data in order to meet its legal obligations, the data processing is lawful.

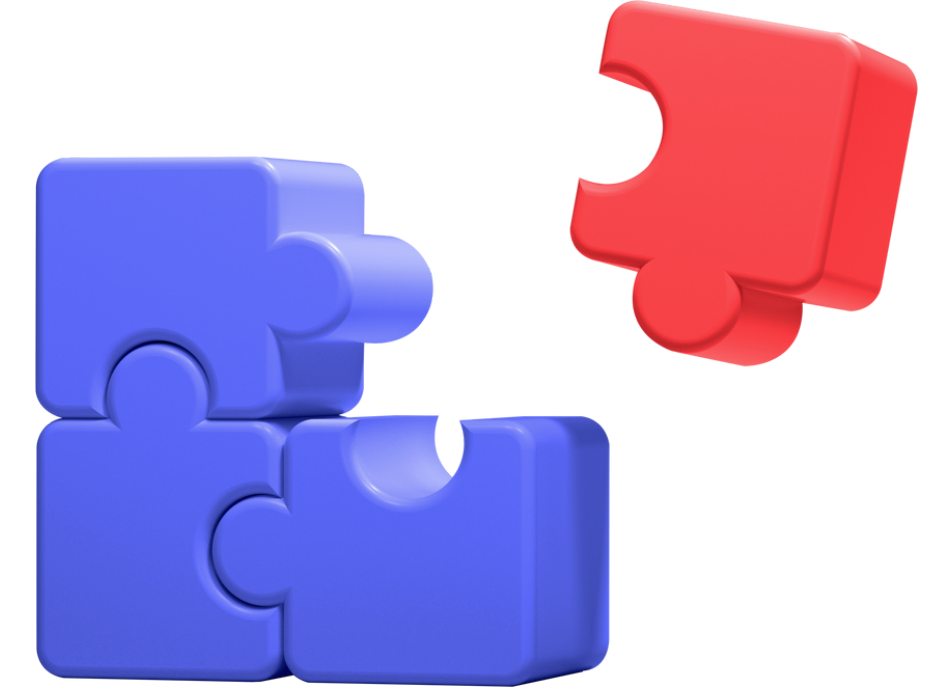


Legitimate interest

It applies when an organization has a legitimate interest in processing the data, and the person's interests, rights, and freedoms do not override this legitimate interest.



KEY TERMS



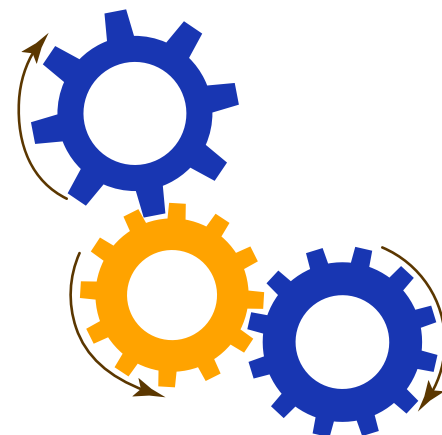
Controller

Natural or legal person, public authority, agency or other body which, alone or jointly with others, determines the purposes and means of the processing of personal data.



Processor

Natural or legal person, public authority, agency, or other body which processes personal data on behalf of the controller



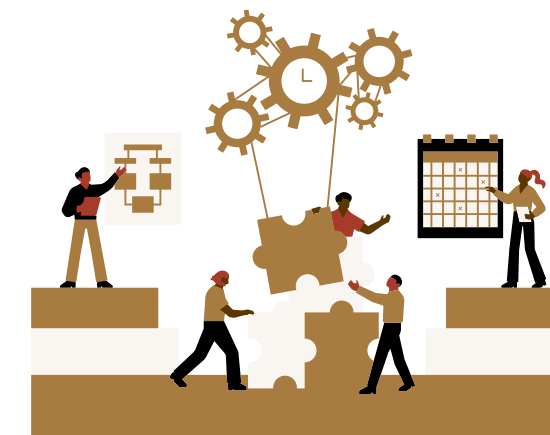
Personal data

Any information relating to an identified or identifiable natural person (“data subject”) such as a name, an identification number, location data, an online identifier



Processing

Any operation or set of operations which is performed on personal data or on sets of personal data

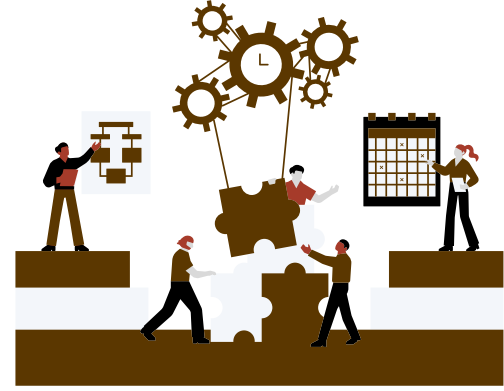


Pseudonymisation

Processing of personal data in such a manner that the personal data can no longer be attributed to a specific data subject without the use of additional information



SECURITY: GDPR

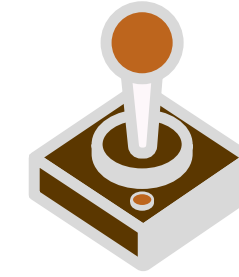


GDPR doesn't mandate the exact security measures organizations must take



It requires organizations to determine security measures themselves, depending on factors like the nature of the personal data, its sensitivity, and the risks involved in the processing.

Security Controls



Identity and Access Management (IDAM):

Ensure that employees have access only to information or systems applicable to their job function.



Data Loss Prevention (DLP)

According to GDPR, organizations, whether they are the controller or processor of personal information, are held liable for the loss of any personal data they collect.

Incorporating DLP controls adds a layer of protection by restricting the transmission of personal data outside the network.



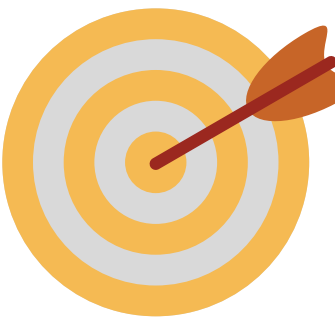
Incident Response Plan (IRP):

A step-by-step process for reporting and mitigating data breaches.

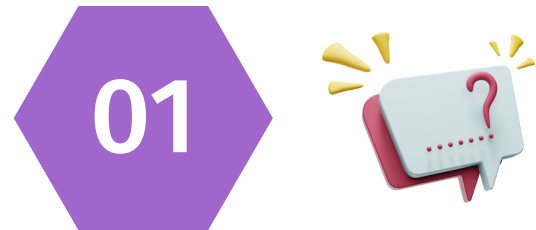


Secure Access Service Edge (SASE):

It recognizes the challenges presented by remote work and operations. SASE differs from traditional models in that it uses cloud services to deploy security protocols to remote locations.



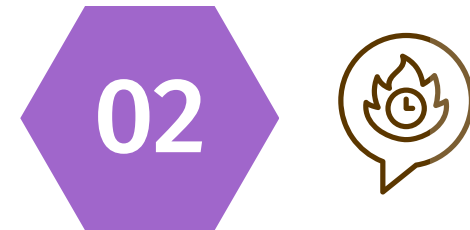
REQUIREMENTS



Data subject rights

Individuals has right to ask the company what information it has about them, and what the company does with this information

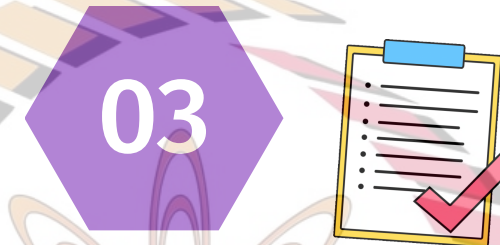
Right to ask for correction, object to processing, lodge a complaint, or even ask for the deletion or transfer of his or her personal data.



Limitation of purpose, data and storage

Forbid processing of personal data outside the legitimate purpose for which the personal data was collected.

Ask that personal data should be deleted once the legitimate purpose for which it was collected is fulfilled



Consent

As and when the company has the intent to process personal data beyond the legitimate purpose for which that data was collected, a clear and explicit consent must be asked from the data subject.

Once collected, this consent must be documented, and the data subject is allowed to withdraw his consent at any moment.



Data Protection Officer

When there is significant processing of personal data in an organization, the organization should assign a Data Protection Officer.

Advises the company about compliance with EU GDPR requirements.



Awareness and training

Organizations must create awareness among employees about key GDPR requirements, and conduct regular trainings to ensure that employees remain aware of their responsibilities with regard to the protection of personal data

INDIVIDUAL RIGHTS



RIGHT-1

Rights to access the personal data organizations hold about individuals

Personal data corrected or deleted (the “right to be forgotten”)



RIGHT-2

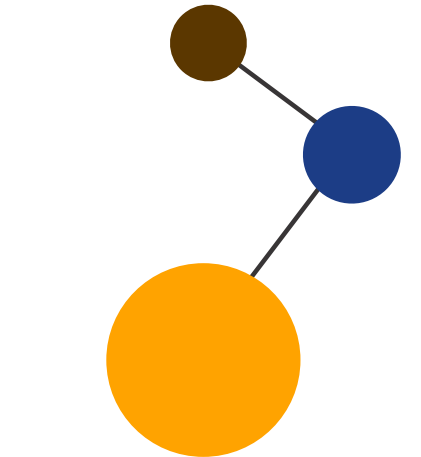
Ask organizations to stop processing their personal data

Revoke consent for certain uses of personal data



RIGHT-3

Right to data portability means organizations must provide individuals their personal data in a way that makes it easy for them to move their personal data elsewhere



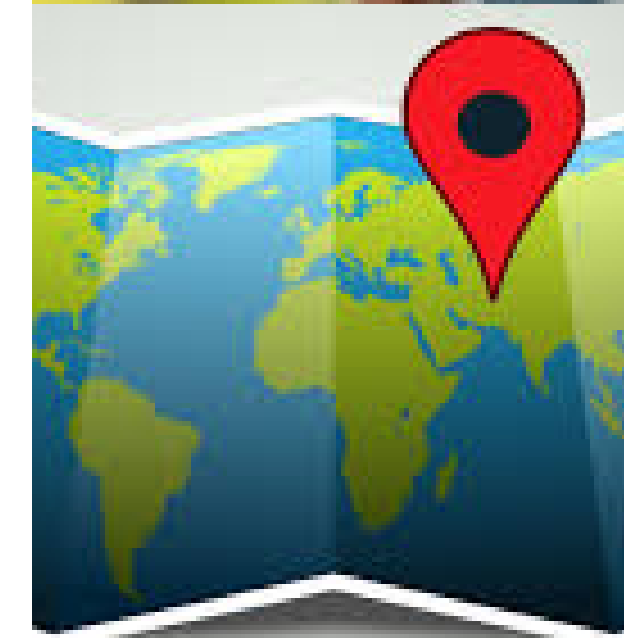


GDPR VS. DATA PROTECTION DIRECTIVE (1995) : WHAT ARE THE KEY CHANGES?

Personal data redefined

GDPR broadens the scope of personal data. It defines personal data as any information that could be used, either on its own or in association with other data, to identify an individual.

Personal data now include IP addresses, mobile device identifiers, fingerprints or retinal scans, geolocation, medical records, socio-cultural information besides names, physical address, phone number, email address etc.





KEY CHANGES IN GDPR - A COMPARATIVE ANALYSIS

Individual Rights : Opt-in and Consent

Under GDPR , organizations are required to secure opt-in and consent for the processing of any personal data of individuals by providing a short but sufficient explanation on its usage through specific GDPR-compliant privacy agreements.

Right to access and right to be forgotten

GDPR empowers individuals by providing them right to obtain from data controllers information on how their data is being used, where, and for what purpose.

Individuals also hold the right of their data to be erased or restrict from further processing.





KEY CHANGES IN GDPR - A COMPARATIVE ANALYSIS

Accountability of Data processors and appointment of data protection officer

- Earlier, under DPD, only data controllers were held accountable for any mishandling of personal data. Under GDPR, Both data controllers and data processors are jointly responsible.
- Data processors to enter into a contract with data controllers defining responsibility of data security during processing of personal data.
- GDPR mandates appointment of a data protection officer who will serve as the central point of contact for inquiries about how personal data are collected and processed.





KEY CHANGES IN GDPR - A COMPARATIVE ANALYSIS

Mandatory Data Protection Impact assessment for High risk project

GDPR makes it mandatory to conduct a Data protection Impact Assessment for High risk projects i.e. working with sensitive personal data on a large scale or profiling vulnerable persons or section of society. DPIA helps identifying probable risks associated with processing of personal data and corresponding mitigation plan.

DPIA is a project specific assessment and not an organizational operation evaluation. It ensures GDPR compliance by enabling the organization to incorporate “data protection by design” into new projects





KEY CHANGES IN GDPR - A COMPARATIVE ANALYSIS

Stringent and Uniform protocols for Data Breach and heftier penalties

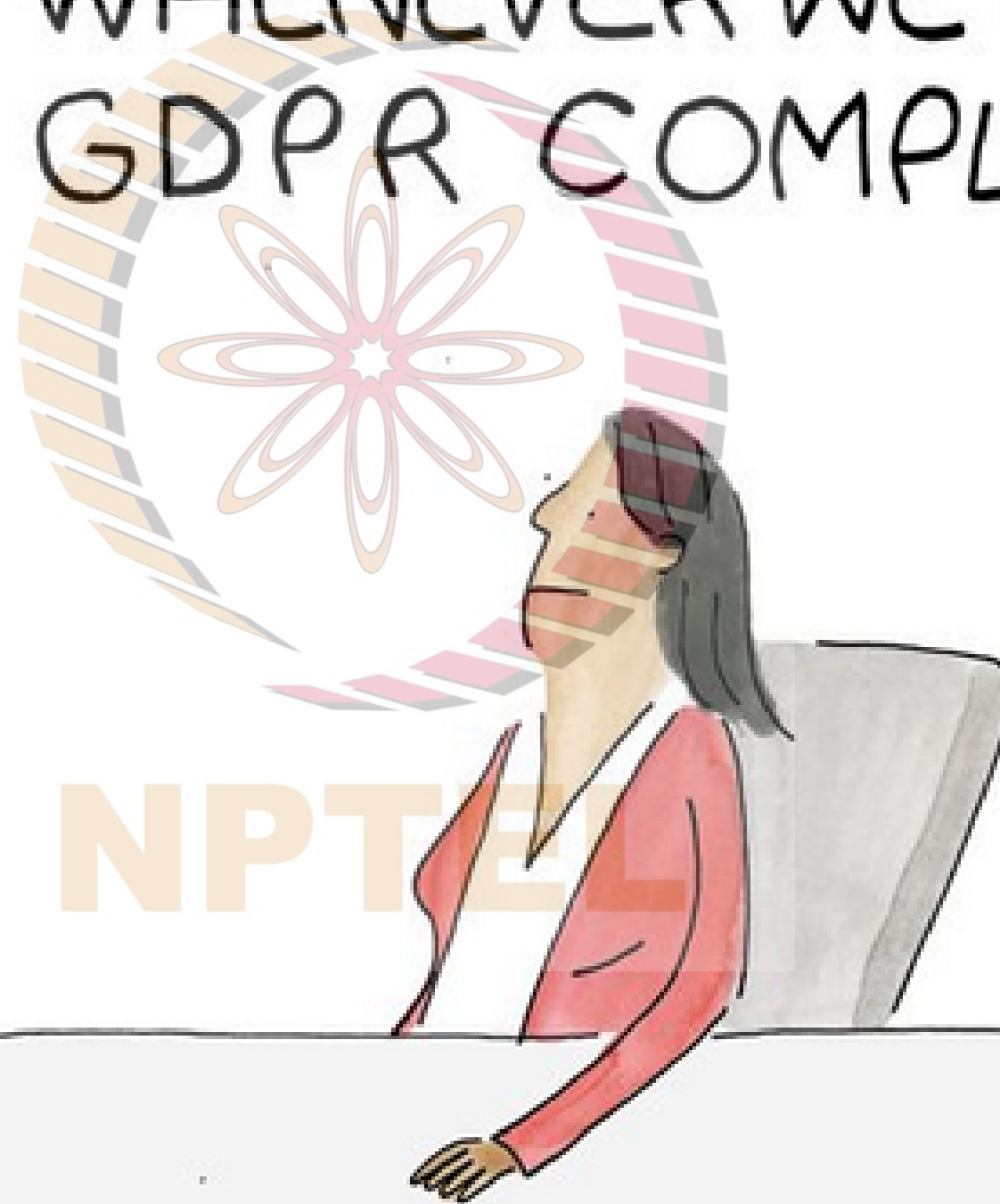
DPD allowed EU member countries to adopt different protocols for data breach, particularly the processes for notifying data subjects. GDPR requires any data breach to be notified to the data subjects and supervisory authority within a span of 72 hours and this applies to all member states.

The fines can be up to 20 million euros or 4% of global turnover of previous fiscal year whichever is higher.





WHY DO YOU GET THAT LOOK
WHENEVER WE TALK ABOUT
GDPR COMPLIANCE?



NPT



“Privacy knows no borders: we have to protect privacy globally or we protect it nowhere!”

Ann Cavoukian
is the former
Information
and Privacy
Commissioner
for the
Canadian
province of
Ontario

1

Full Functionality – Positive-Sum, not Zero-Sum

2

End-to-End Security – Full Lifecycle Protection

3

Visibility and Transparency

4

Open Respect for User Privacy – Keep it User-Centric

5

Proactive not Reactive; Preventative not Remedial

6

Privacy Embedded into Design

7

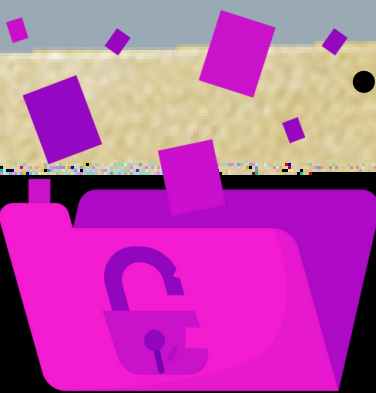
Privacy –Default Setting

> Privacy by Design and Default



- ENCOMPASSES APPLICATIONS:

- 1) IT SYSTEMS



Record-keeping Requirements

01



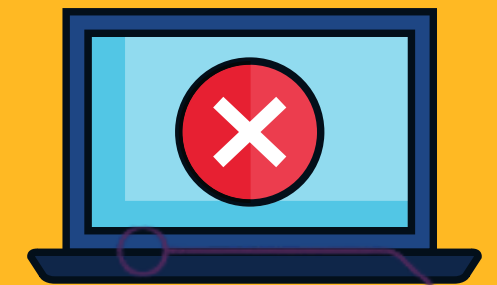
Organizations to maintain accurate and up-to-date records of their processing activities

02

- Records to give
 - purposes of the processing
 - categories of data processed
 - details of 3RD parties involved

03

Organizations to keep records of data breaches and response measures



Do you know a good GDPR consultant?

Yes.

Can you give me his e-mail address?

No.

THATS GDPR!!

NPTTEL



Need and Practice of Data Protection Impact Assessments



DPIA

Any new processing activity-new risk to rights and freedoms of individuals

COVERS

1

NATURE, SCOPE, CONTEXT, AND PURPOSES OF THE PROCESSING,

2

LIKELIHOOD AND SEVERITY OF ANY POTENTIAL HARM TO INDIVIDUALS.



WHAT AFTER DATA BREACH??



**NOTIFY authorities
WITHIN 72 hrs**

**Inform
the affected
individuals**



**Adequate tech and org
measures to detect, report, and
investigate
personal data breaches.**



```
("show.bs.tab",{relatedTarget:e[0]  
this.activate(h,h.parent(),function  
type.activate=function(b,d,e){func  
tab"]').attr("aria-expanded",!1),  
veClass("fade"),b.parent(".dropdo  
)}var g=d.find("> .active"),h=e&&  
ionEnd",f).emulateTransitionEnd  
Conflict=function(){return a.fn.t  
="tab"]',e).on("click.bs.tab.data  
(this),e=d.data("bs.affix"),f="ob  
({}),c.DEFAULTS,d),this.$target=a  
api",a.proxy(this.checkPositionW  
"3.3.7",c.RESET="affix affix-top  
is.$element.offset(),g=this.$targ  
&&"bottom":!(e+g<=a-d)&&"bottom"  
tPinnedoff
```





DATA TRANSFER PREREQUISITES OUTSIDE EU

COUNTRIES OUTSIDE OF THE EU

- Recipient country provides protection in accordance with GDPR

TRANSFER DATA TO

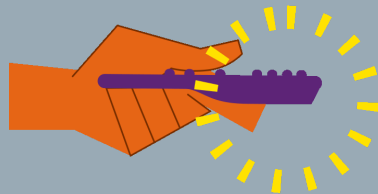
COUNTRIES THAT DO NOT PROVIDE ADEQUATE PROTECTION

- Implement appropriate safeguards such as standard contractual clauses, binding corporate rules, or Privacy Shield.

TRUST ME. OUR
CLOUD SECURITY IS SO
GOOD EVEN YOU WON'T BE
ABLE TO ACCESS YOUR
DATA!



THINGS TO KNOW IF BUSINESS VENDOR PROCESSES PERSONAL DATA



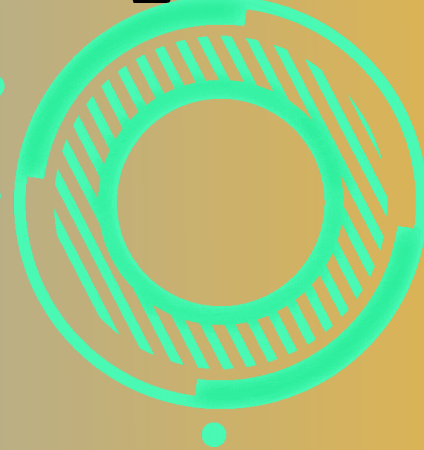
2

OWNER IS "CONTROLLER"

1

PERSONAL DATA

VENDOR IS "PROCESSOR"



3

WRITTEN AGREEMENT



4

- Sets out Obligations & Responsibilities
- Processing to Comply with GDPR
- Data protection measures



MICROSOFT PERFECT FOR GDPR

Microsoft offers a range of services and tools to organizations TO meet obligations under the GDPR.



KEY TAKEAWAY

**TOOLS FOR DATA PROTECTION
IMPACT ASSESSMENTS, DATA
MAPPING, DATA PROTECTION
BY DESIGN AND BY DEFAULT.**

CLOUD DATA SERVICES

**DATA ENCRYPTION ACCESS
CONTROL,**

What impact will the GDPR have on organizations?

six major areas that companies will have to consider:

Data protection through technology – Art. 25 GDPR

Data protection through technology (by design) and as a standard approach (by default).

Like minimizing and pseudonymizing the processing of personal data.

Heightened Accountability – Art. 5 GDPR

Ensure and demonstrate adherence to data protection regulations,

Like through certification.

Immediate notification requirements – Art. 33 GDPR

Report data breaches within 72 hours, Failure results in fines of up to 20 million euros or 4% of company's global annual turnover.

Data protection officer – Art. 37–39 GDPR

Responsible for informing and advising employees who carry out processing; Monitoring compliance with the GDPR and national data protection provisions;

Awareness raising and training. Advise on DPIA monitoring .

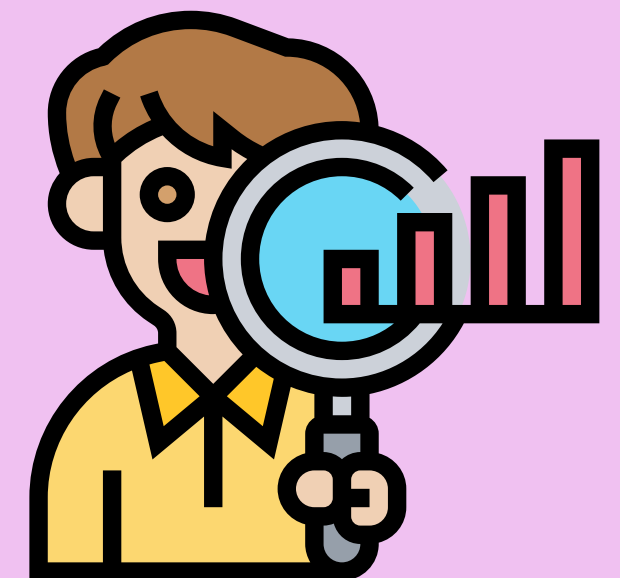
Data Protection Impact Assessment (DPIA) – Art. 35 GDPR

DPIA required for using new technologies, Data protection officer submits declaration after analysing process & technology & legality of the data processing.



Penalties and fines – Art. 83–84 GDPR

More severe fines and penalties designed to deter companies . Other penalties, such as seizure of profits, injunctions to end infringements, and permanent prohibition of data processing may also be imposed.



GDPR and the Pandemic

- As per IT Governance's figures median GDPR penalty was €2,000.
- 306 fines in 2020 totalling €182,546,779.
- 429 GDPR fines issued 2021 – fines totalling €1,098,942,386.84 – a sevenfold increase.
- Rise in regulatory penalties linked to the data protection due to COVID-19– as organizations shifted to fully remote or hybrid working solutions –with little or no existing infrastructure to support homeworkers.
- Organisations struggled in hostile work environment as countries again locked down due to second wave
- Significant increase in cyber attacks by criminals seeking to exploit the pandemic by targeting people's uncertainty and their inability to rely on robust in-house security defences.

Facebook and Google hit with \$8.8 billion in lawsuits on day one of GDPR

By Russell Brandom | @russellbrandom | May 25, 2018, 10:21am EDT

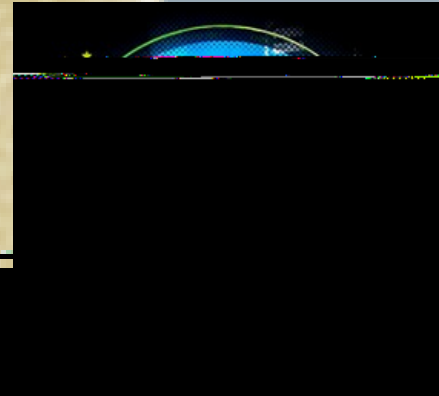


The Conclusions And Way Forward

- **Privacy Is Here To Stay** – Two years ago, privacy was not the norm but going forward privacy is going to be the new normal. Consumers will expect it, Authorities will check it and the Corporates will do it.
- **There Will Be More Automation** – Till now focus was on becoming compliant by setting and operationalizing the policies, governance, and processes. With more automation, usage of Artificial Intelligence, challenges shall grow.
- **The Maturity Will Only Increase** – For most organizations, these are early stages of privacy compliance. In the coming years, there is likely to be an increase in maturity.
- **There Will Be different Privacy Laws** – Lot of countries have already passed privacy laws, coming years will see more. Compliance across different privacy laws across the globe will remain a big challenge for most countries operating in multiple countries.
- **Privacy Will Become A Brand Differentiator** – Privacy compliance will become a brand differentiator in terms of winning more clients. A study by CISO shows that 82% of organizations view privacy certifications such as ISO 27701 and Privacy Shield as a buying factor when selecting a product or vendor in their supply chain. And, this is only going to increase and become a mandatory requirement.

In short, like it or not-- GDPR and privacy laws are here to stay.

We can always debate that this is not there and that is not fair but the law is there. And, we are better off taking a practical approach to complying with the longer-term perspective.



Australia – the Privacy Amendment (Notifiable Data Breaches) to Australia's Privacy Act came into effect in February 2018.

Brazil – Brazil's Lei Geral de Proteção de Dados (LGPD) is modeled on GDPR , but with less harsh financial penalties for non-compliance.

Canada–Has implemented Digital Charter Implementation Act, amending its digital data privacy policies. Personal Information Protection and Electronic Documents Act (PIPEDA) 2000. most recently amended in November 2018 to include mandatory data breach notification. data privacy is governed by the Privacy Act 1983.

China – The People's Republic of China passed the Personal Information Protection Law (PIPL), which came into effect in November 2021. companies that do business in China, regardless of any physical presence in the country, have to comply or be subject to fines of up to 6 million EUR) or 5% of global annual turnover,

India – India's Personal Data Protection Bill (PDPB) introduced in December of 2019 and likely to pass this year. Companies all over India are already beginning to prepare. PDPB is modeled after GDPR .Heavy fines for noncompliance that may be as high as 4% of global annual turnover.

Israel – In addition to Israel's Protection of Privacy Law of 1981, which deals with privacy in general, handling of digitized personal data is also covered by other data privacy regulations that deal with data security (2017) and international transfer of data (2001).

Japan – Japan's Act on Protection of Personal Information, 個人情報保護法, was amended in May 2017 and now applies to both foreign and domestic companies that process the data of Japanese citizens. Companies located outside of Japan will now be subject to the strict guidelines laid down in the Act.

South Africa – South Africa's Protection of Personal Information Act (POPIA) came into effect on July 1, 2020 with an exactly one year grace period.

South Korea –South Korea's Personal Information Protection Act, has been in effect since September of 2011 and from the outset has included many GDPR-like provisions,

Ref: <https://www.i-sight.com/resources/a-practical-guide-to-data-privacy-laws-by-country/#India>

